

Mapeo Detallado GQM a Requisitos Normativos

Pirámide del Dolor + GQM + PRAGMATIC

La tabla siguiente vincula los objetivos GQM definidos en el marco integrativo con referencias normativas y marcos habituales (NIS2, ENS, ISO 27001, etc.), de forma que cada objetivo y su familia de métricas puedan contextualizarse en términos de cumplimiento y buenas prácticas.

Nota: las referencias son orientativas y deben adaptarse a la versión y transposición específica de cada norma.

Objetivo GQM	Descripción resumida	NIS2 / Directivas UE	ENS / España	ISO / Estándares	Marcos técnicos	Comentario
G1	Mejorar eficiencia de uso de IoC de bajo nivel	NIS2 – Art. 21 (gestión de riesgos y medidas técnicas)	ENS – PR.1, PR.2 (protección), OP.3 (operación segura)	ISO 27001 – A.12 (operaciones), A.13 (comunicaciones)	STIX/TAXII, CTI	Alinea la gestión de IoC con obligaciones de detección y respuesta.
G2	Gestión disciplinada de listas de IP/dom. maliciosos	NIS2 – medidas técnicas proporcionales	ENS – OP.2, OP.3	ISO 27001 – A.12, A.13	Threat Intel Feeds	Evita dependencia en listas obsoletas; encaja en operación segura.
G3	Aumentar detección por artefactos antes de incidentes graves	NIS2 – Art. 23 (det. y notificación incidentes)	ENS – OP.3 (detección), OP.4 (respuesta)	ISO 27001 – A.16 (gestión de incidentes)	NDR, EDR/XDR	Conecta detección intermedia con requisitos de gestión de incidentes.
G4	Optimizar reglas de artefactos, reducir ruido	NIS2 – eficacia de medidas técnicas	ENS – MP.2 (mejora continua)	ISO 27001 – Cláus. 9 (evaluación desempeño)	Buenas prácticas SOC	Relacionado con mejora continua y uso eficiente de recursos.
G5	Incrementar detecciones en capas altas (TTP)	NIS2 – abordaje de ciberamenazas avanzadas	ENS – OP.3, MP.2	ISO 27001 – enfoque basado en riesgo	MITRE ATT&CK	Apoya la adopción de detecciones avanzadas como “estado del arte”.
G6	Cobertura mínima ATT&CK por sector	NIS2 – requisitos sectoriales de seguridad	ENS – MP.2, OP.3	ISO 27001 – A.18 (cumplimiento)	ATT&CK, D3FEND	Facilita la definición de “buenas prácticas” sectoriales.

G7	Reducir MTTD/MTTR mediante detecciones de calidad	NIS2 – gestión y mitigación de incidentes	ENS – OP.4 (respuesta), OP.5 (recuperación)	ISO 27001 – A.16, ISO 22301	SOC, IR playbooks	Métricas clásicas de incidentes, enriquecidas con enfoque piramidal.
G8	Demostrar ROI de inversiones en detección de alto nivel	NIS2 – proporcionalidad y eficiencia	ENS – MP.2 (mejora continua), OR.1 (organización)	ISO 27001 – planificación y mejora	Modelos de costes	Da soporte cuantitativo a decisiones de inversión.
G9	Potenciar intercambio de información de alto valor	NIS2 – cooperación y CSIRTs	ENS – CO.1 (relaciones con terceros)	ISO 27010 (intercambio inter-org.)	ISACs, CSIRTs	Refuerza la dimensión colaborativa exigida por NIS2.

Uso práctico del mapeo

- Para reguladores / organismos nacionales: vincular objetivos GQM con exigencias de NIS2 y ENS, justificando por qué se piden ciertas métricas.
- Para organizaciones: demostrar que las iniciativas de mejora en TTP y detección avanzada no son “extras”, sino parte de la respuesta razonable a marcos de referencia.
- Para auditores: utilizar los objetivos GQM como referencia para evaluar si se mide lo que las normas esperaban, aunque no lo dijeran con estas palabras.

El detalle fino (artículos concretos, medidas específicas del ENS por categoría) se puede completar en función del sector y tipo de organismo.